

UNIT 2 NOTES
V SEMESTER CYBER SECURITY
COMPUTER SECURITY COURSE(CCT302)

Unit 2: Threats and Vulnerabilities

Understanding Studies & Surveys of Computer Crime, Psychology of Computer Criminals, Looming Threats - Insider Threat & Information Warfare, Computer System Penetration Malicious Code & Fooling Attacks, Mobile Code, Social Engineering & Low-Tech Attacks, Web-Based Vulnerabilities, Physical Threats to Computer Systems

Understanding Studies & Surveys of Computer Crime

THE PSYCHOLOGY OF COMPUTER CRIMINALS

Symantec's Internet Security Threat Report for 2011 indicated an 81 percent increase in network attacks compared to 2010; this, coupled with a reported 187 million identities that were exposed due to outsider attacks, suggests that the threat of computer crime is growing to unprecedented levels.

SELF-REPORTED MOTIVATIONS. Perhaps the simplest approach to understanding the mindset of computer criminals is having the perpetrators describe their motivations in their own words. Using various self-reporting measures, including surveys, open-ended questionnaires, and first-person interviews, researchers have consistently found a number of common accounts used by computer criminals to explain and justify their illicit and sometimes harmful behaviors.

According to sociologist Paul Taylor, computer criminals report that they are motivated by an interacting mix of six primary categories: addiction, curiosity, boredom, power, recognition, and politics.

PSYCHOLOGICAL PERSPECTIVES ON COMPUTER CRIME. Although self-reporting analyses can give us some insight into the motivations behind computer criminals, these types of descriptive methodologies typically yield incomplete and sometimes inaccurate results. Unless the causes for our behaviors are obvious, our explicit or consciously held explanations for our actions are often misguided. Research has found that our behaviors are frequently controlled by subtle situational variables and implicit attitudes of which we are not typically aware, and may be distinctly different from the conscious mechanisms we use to explain our actions. Therefore, our conscious justifications for our actions may be inaccurate if we are unaware of more subtle cognitive processes.

Five-Factor Model of Personality and Computer Criminals

The five-factor model formulated by psychologists Robert McCrae and Paul Costa in 1990 suggests that an individual's personality can be accurately described using five core dimensions: extraversion (e.g., sociable), neuroticism (e.g., anxious), agreeableness (e.g., cooperative), conscientiousness (e.g., ethical), and openness to experience (e.g., nonconforming).

Rogers hypothesized that individuals engaging in computer crime would demonstrate higher levels of:

- _ exploitation,
- _ hedonistic morality,
- _ manipulation,
- _ antagonism,
- _ undirected behaviors,
- _ introversion,

- _ openness to experiences, and
- _ neuroticism

Internet Abuse and Computer Crime.

Although *technological addiction* is not a disorder recognized by the American Psychological Association (APA), researchers have suggested that some individuals appear to demonstrate disturbed computer use that is similar to other recognized disorders like compulsive gambling or impulse control disorders. Technological addiction is characterized by:

- _ Excessive use of a particular technology (usually in reference to computers and Internet usage)
- _ Preoccupation with the technology
- _ Systematic increase in use
- _ Failed attempts to curb one's use
- _ Feelings of malaise and irritation when not using the technology
- _ Interference with social and professional pursuits due to excessive technology use

CLASSIFICATIONS OF COMPUTER CRIMINALS.

For both ordinary and abnormal behaviors, it is difficult to find one theoretical perspective that can account for every behavior in a given situation. Attitudes and behaviors are the product of the combined influence of an individual's personality and the current social situation. No single theory or theoretical perspective can account for the various types of computerized crimes and the criminals who engage in these activities. There are also many types of computerized crimes, ranging from trading pirated software to cyberterrorism, and many types of computer criminals, ranging from the novice password cracker to the industrial spy. Any theory that would account for the behavior of computer criminals would have to consider, first, the type of illegal activity the person was engaged in and, second, the type of cybercriminal category that the individual falls into. The term *computer hacker* has been both overused and misused as a way of classifying the entire spectrum of computer criminals.

Bill Landreth, a reformed computer cracker, was one of the earliest theorists to develop a classification scheme for computer criminals. His system divided criminals into five categories based on their experience and illegal activities

1. The *novice* criminals have the least experience with computers and cause the least amount of electronic disruption from their transgressions. They are considered to be tricksters and mischief-makers; for example, AOL users who annoy chatroom members with text floods and DoS-like *punting* programs that crash AOL sessions using specific font or control code strings.
2. The *students* are electronic voyeurs. They spend their time browsing and exploring unauthorized computer systems.
3. The *tourists*, according to Landreth, commit unauthorized intrusions for the emotional rush that results from their actions. This subgroup of computer criminals is similar to Bequai's electronic joyriders.¹⁵⁵ The tourists are thrill-seekers who receive a cerebral buzz from their illegal behaviors.
4. The *crashers* are malicious computer criminals. This subgroup is composed of the darkside criminals that Kabay refers to.¹⁵⁶ The crashers will crack into networks and intentionally delete and destroy data and cause denials of service.
5. Landreth's final classification of computer criminal is the *thieves*. Criminals who fit into this category commit their illegal actions for monetary gain. These individuals are equivalent to the dangerous insiders that Post, Shaw, and Ruby analyzed.¹⁵⁷ Thieves may work alone, or they may be under contract from both foreign and domestic corporations and governments. Examples include the Russian Business Network or RBN.

Chantler used to create three categories of computer criminals: *lamers*, *neophytes*, and *elites*.

1. **Lamers** have the least technical skill and they have been engaged in their illegal activities for the shortest period of time. This group of criminals is primarily motivated by revenge or theft of services and property.
2. **Neophytes** are more mature than lamers. They are more knowledgeable than the previous category and engage in illegal behaviors in pursuit of increased information.
3. **Members of the elite** group have the highest level of overall knowledge concerning computers and computer crime. They are internally motivated by a desire for knowledge and discovery. They engage in illegal activities for the intellectual challenge and for the thrill they receive from their criminal behaviors.

Information security analyst Donn Parker developed a seven-level categorization scheme for computer criminals. He formalized his scheme, through years of interaction and structured interviews with computer criminals, into the following categories:

1. **Pranksters** are characterized by their mischievous nature.
2. **Hacksters** are motivated by curiosity and a quest for knowledge. Pranksters and hacksters are the least malicious computer criminals.
3. **Malicious hackers** are motivated by a need for disruption and destruction. They receive pleasure from causing harm to computer systems and financial loss to individuals.
4. **Personal problem solvers** commit illegal activities for personal gain. Problem solvers, the most common type of computer criminal according to Parker, resort to crime after failing in legitimate attempts to resolve their difficulties.
5. **Career criminals** engage in their illegal cyber behaviors purely for financial gain.
6. **Extreme advocates** have strong ties to religious, political, or social movements. Recently, these types of cybercriminals have been dubbed “hacktivists,” a combination of computer hackers and activists.
7. **Malcontents, addicts, and irrational individuals** comprise the final category in Parker’s scheme. Individuals in this category usually are suffering from some form of psychological disorder (e.g., antisocial personality disorder).

Rogers’s New Taxonomy of Computer Criminals.

After an extensive review of past categorization theories, Rogers has advanced an updated continuum of computer criminals based on his previous work. This continuum comprises eight categories based primarily on the criminals’ motivations and technological prowess:

1. **Novice (NV)** criminals have the least amount of technical knowledge and skill. Members of this category are relatively new to the scene and use prewritten and precompiled scripts and tools to commit their computerized crimes. They are primarily motivated by the thrill of lawbreaking and making a name for themselves in the underground.
2. **Cyber Punk (CP)** is the group that most fits the traditional stereotype of hacker. Members of this category are slightly more advanced than the novices. These criminals have the ability to create basic attack scripts and programs. Cyber Punks’ typical behaviors include Web page defacements, DDoS attacks, carding, and telecommunication fraud. They are motivated by a need for attention, fame, and monetary gain, usually attained by parlaying their crimes into lucrative jobs and book deals.
3. **Internals (IN)** consist of disgruntled workers or former workers who hold information technology positions in an organization. Members of this category have an advantage over external attackers due to their job and status within the corporation. Research indicates that internals are responsible for the majority of computer crimes and associated financial loss. Their motivation is typically based on revenge for some perceived wrong (e.g., termination, passed over for a promotion)
4. **Petty Thieves (PT)** are traditional criminals who have turned to technology as a way of keeping up with the times. These individuals are career criminals whose motivation is primarily financial gain from stealing from banks, corporations, and individuals.
5. **Old Guard (OG)** are computer criminals with advanced technical knowledge and skill. These individuals are responsible for writing many of the exploit programs (e.g., stack overflows, rootkits, etc.) that are used by the less knowledgeable novice and cyberpunk crackers in their cyberattacks;

however, they are not criminals in the traditional sense. This group has an underdeveloped sense of ethics regarding privacy and intellectual and personal property and engages in behaviors consistent with the traditional hacker ethic and ideology. Their illegal behaviors are motivated by a quest for knowledge, curiosity, and intellectual stimulation.

6. **Virus Writers (VW)** do not fit neatly into Roger's Taxonomy primarily due to the lack of research on this group of individuals.
7. **Professional Criminals (PC)** are traditionally older and more knowledgeable about technology than the previous categories. Members of these categories may be former government and intelligence operatives who are motivated by financial gain. They may often have access to advanced technology and can be adept at industrial espionage. According to Rogers, PCs may be comprised of ex-intelligence agents and are one of the most dangerous types of computer criminals. Their motivation is primarily large-scale financial gain.
8. **Information Warriors** are highly skilled employees who conduct coordinated attacks against information systems in an attempt to cripple or destabilize the infrastructure. This group may be motivated by allegiance and patriotism.

Hactivists and Cyberterrorists: Hacking for a Cause.

With the emerging protests against the economically advantaged 1 percent and the political upheaval in the Middle East, new trends in cybercrime have emerged in the form of a revitalized hactivist ethos. **Hactivism is defined as cause-based hacking for social, political, patriotic, or religious purposes.** In general, the perpetrators engage in technological dissent in order to promote freedom of speech and fair distribution of wealth and to combat censorship. **Hactivists will often rally behind a symbol, logo, or flag, whether they are religious, political, or emblematic. The term was first used by groups like Electronic Disturbance Theatre (EDT) and the Cult of the Dead Cow(cDc) in the mid-1990s** to establish digital protests and *hack-ins* where the groups would launch coordinated DoS attacks and mass Web page defacements as a means of online protest.

A **cyber-terrorist** is defined as, "an individual who uses computer or network technology to control, dominate, or coerce through the use of terror in furtherance of political or social objectives." Following the September 11, 2001, attacks in the United States, the term cyberterrorism has been frequently overused and misused by the media. An individual who stumbles upon a vulnerable .mil or .gov Website and decides to deface it should not be considered a cyberterrorist unless there is a premeditated intent to cause panic and fear, with the object of obtaining some social end.

Dangerous/Malicious Insiders (DI/MI).

Dr. Eric Shaw and associates classify computer criminals into two categories: outside intruders and dangerous insiders. The researchers focus on the critical IT insiders who are typically programmers, technical support staff, networking operators, administrators, consultants, and temporary workers in organizations. Malicious insiders (MI) are a subgroup of such employees who are motivated by greed, revenge, problem resolution, and ego gratification. Critical-pathway approach identifies psychological and situational precursors that may predispose an employee to engage in insider espionage:

1. **Personal Predisposition:** medical/psychiatric problems, reduced social skills, previous violations of the law or business ethics, social or professional ties with competitors or adversaries
2. **Personal Life Stressors:** financial burden, relationship problems, medical issues, legal issues
3. **Professional Stressors:** demotions, failed promotions, poor performance review, transfer, supervisor disagreements, looming layoffs
4. **Concerning Behaviors:** workplace violations, conflict, intellectual property (IP) disagreements
5. **Maladaptive Organizational Responses:** failure to detect, investigate, appreciate, and appropriately respond to concerning behaviors of employees

Virus Creators.

Unlike more traditional forms of computer crime, there has been very little research examining the motivations and behaviors of malware writers, usually referred to as *virus writers*. Despite the name, the group writes other forms of malware such as worms and Trojans. The limited number of research reports on this particular subgroup of computer criminal has relied primarily on one-on-one interviews and surveys, in an effort to understand the actions and motivations of virus creators. Using case studies and multiple interviews, researchers Andrew Bissett and Geraldine Shipton examined the factors that influence and motivate virus writers. The researchers suggest that it is difficult to generalize their findings to all virus creators because of the limited published literature and research regarding virus writers. Virus creators appear to demonstrate conscious motivations for their potentially destructive actions that are similar to the motivations of traditional computer criminals. The coders create and distribute their software for reasons of nonspecific malice, employee revenge, ideological motives, commercial sabotage, and information warfare.

THREATS FROM INSIDERS

Successful organizations need to have people in many different roles, with the primary distinction between business roles (business management, sales, customer services, and product design) and support/infrastructure roles (IT, finance, logistics, human resources, and the like). The people in each role need access to information and systems to perform their role, and the key point to make at this stage is that the impact an insider attack makes on the organization is related to the insider role. A salesman leaving an organization to join a competitor will have had access to customer- and product-related information, whereas someone in product design is likely to have access to valuable intellectual property on current and future products. Customer service center staff are likely to have access to customers' personally identifiable information (PII) that can be used to commit identity fraud. IT is a high-risk area, and is essential to the efficient running of the business. Most of an organization's information is stored in its IT systems, and without proper controls, IT administrators could have access to everything.

[How Common Are Insider Attacks?](#)

According to the 2011 CyberSecurity Watch Survey,¹ 21 percent of electronic crime events were conducted by insiders, 58 percent by outsiders, and 21 percent unknown. Of the insider events, 76 percent were dealt with internally without legal action or law enforcement, which is likely a reason that external attacks are more often in the news.

Examples of Insider Attacks.

To get an understanding of the types of insider events, a number of organizations maintain databases and publish results. The FBI maintains an Insider Threat page on their Website⁴ containing a list of prosecuted insider theft cases. A short summary of these cases follows:

- _ Retired research scientist conspired with current and former employees to steal trade secrets from his former employer, and sell them to companies in China.
- _ Employee working for two different U.S. companies stole trade secrets from both companies which were used to benefit Chinese universities.
- _ A research scientist stole trade secrets from her employer and made them available for sale through her own company.
- _ An employee stole customer and employee lists, contract information, and other trade secrets to provide to a foreign government, but instead gave them to an undercover FBI agent.
- _ A computer programmer working for a financial firm copied proprietary software during his last few days at the company.
- _ An employee who was fired had kept copies of trade secrets. These trade secrets were then sold to a rival company.

Types of Insider Threats.

There are three main classifications of insider threats: **accidental, malicious, and nonmalicious.**

Accidental Threats. Accidental threats are generally caused by mistakes; for example, staff may not follow operating procedures due to carelessness, disregard for policies, or a lack of training and awareness of the right thing to do. An example is a customer service representative who accidentally breaches client confidentiality by emailing client information to the wrong email address.

Malicious Threats. Malicious threats deliberately try to damage the organization or to benefit the attacker. Disgruntled IT administrators can sabotage IT systems, bringing an organization to a halt. There have been many incidents where both current and former administrators have deliberately caused system issues for various motives: enjoying the lifestyle of traveling around the world in luxury to fix the problems they created, extorting money from the organization, or simply causing as much damage as possible.

Nonmalicious Threats. Nonmalicious threats are actions taken deliberately by people without intent to damage the organization. Often, the motive is to increase productivity, and the mistakes occur due to a lack of training or awareness of policies, procedures, and the risk. There have been many incidents in which staff loaded internal information onto Internet-based systems, some of which have no access controls. This error makes the information available to anyone who uses the sites and is often found and indexed by search engines.

MITIGATING THE INSIDER THREAT

System and Asset Inventories. If you don't know what you have, you can't manage it. Without an inventory of servers, you can't ensure they are patched, enabling an insider to compromise them and use them for their own purposes. Without a list of applications running on each server, you may have unnecessary servers sitting on your network being used for unauthorized purposes. The active systems on the network also need to correlate to the inventory. An administrator who doesn't remove a redundant system in your Internet DMZ could use it to bypass all of your network perimeter controls after he has left the organization.

Data Loss Prevention (DLP). There have been technology adoptions over the last 10 years which have made it much easier for staff to either accidentally or deliberately breach the confidentiality of organizational and client information. Data loss prevention (DLP) is a class of IT security system increasingly being implemented by organizations to help address these risks. A typical DLP system needs to address the following vulnerabilities at a minimum:

- _ Mobile storage devices/removable media, such as USB memory sticks and hard drives, mobile phones, memory cards, CD/DVD writers, along with infrared, Bluetooth, FireWire, and SCSI-connected storage.
- _ File uploads—including encrypted data—to external Websites via the standard protocols within Web browsers, such as ftp, http, and https. These controls may be enforced at both the Internet gateway as well as on the desktop.
- _ Detection of when laptops are not on the corporate network and preventing files

Internal Honeypots. Honeypots are attractive systems or nodes that appear to have valuable confidential data.

WEAPONS OF CYBERWAR.

The weapons used in information warfare have existed for many years, but newer and more malevolent versions are produced with increasing frequency. For this reason, system security cannot be considered as static, but rather as part of an ongoing process that must be continuously monitored and strengthened.

Denial of Service and Distributed Denial of Service. Denial of service (DoS) and distributed denial of service (DDoS) are means by which computers, network servers, and telecommunications circuits can be partially or completely prevented from performing their designated functions. Any computer element that has been designed for a specific maximum capacity, if flooded by messages or data inputs that greatly exceed that number, can be slowed or even brought to a complete halt. A DoS attack is carried out by a single computer that has been programmed to overwhelm the target system's capacity, usually by generating, automatically, a very large number of messages. A DDoS attack is implemented by planting a small program on hundreds or thousands of unaware computers. At a signal from the attacker, all of the agents (sometimes called zombies or daemons) are caused to send many messages simultaneously, thus flooding the victim's system or preempting all of its bandwidth capacity.

Malicious Code. Malicious code includes viruses, worms, and Trojan horses. There have been innumerable instances where malicious code has been used to damage or deface websites, both civilian and military. Apparently, all of these exploits have been perpetrated by single individuals or by very small groups of unaffiliated crackers. However, in the event of actual cyberwar, it seems certain that large groups of coordinated, technically knowledgeable attackers will attempt to wreak havoc on their opponents' infrastructures through the use of malicious code.

Cryptography. Military operations, since the earliest recorded times, have utilized cryptography to prevent critical information from falling into enemy hands. A major issue, yet to be resolved, is the strength of cryptographic tools that may be sold domestically or exported overseas. The contending forces include producers of cryptographic tools who believe that if the strength of their product is in any way restricted, they will lose their markets to producers in other countries with more liberal policies. Similarly, proponents of privacy rights believe that unbreakable cryptographic tools should be freely available.

Psychological Operations. Psychological operations (PSYOP) may be defined as planned psychological activities directed to enemy, friendly, and neutral audiences in order to influence their emotions, motives, attitudes, objective reasoning, and behaviors in ways favorable to the originator. The target audiences include governments, organizations, groups, and individuals, both military and civilian. One of the most potent weapons in information warfare, PSYOP attempts to:

- _ Reduce morale and combat efficiency within the enemy's ranks
- _ Promote mass dissension within, and defections from, enemy combat units and/or revolutionary cadres
- _ Support our own and allied forces cover and deception operations
- _ Promote cooperation, unity, and morale within one's own and allied units, as well as within friendly resistance forces behind enemy lines

Physical Attacks. Prior to September 11, 2001, physical attacks, as a part of cyberwar, were generally considered in the same light as attacks against any military objective, and defensive measures were instituted accordingly. In the civilian sector, starting with student attacks against academic computers in the 1960s and 1970s, there have been occasional reported physical attacks against information processing resources. Although access controls have been almost universally in place, their enforcement often has been less than strict. Another indication of the susceptibility of the information infrastructure to physical attack is the prevalence of "backhoe attacks" in which construction crews accidentally slice through high-capacity optic cables used for telecommunications and as part of the Internet backbones

Biological and Chemical Weapons and Weapons of Mass Destruction.

Although the use of these weapons can affect every element of society, they have a particular potency in destroying the infrastructure of a targeted nation. The WTC attacks have had long-lasting psychological effects, but the results of the anthrax dissemination may be even more deeply traumatic. Already, the presence of anthrax spores has interfered with the functioning of the Congress, the Supreme Court, the U.S.

Postal Service, hospitals, and other institutions. Although the furor over these attacks, as well as their incidence, has dissipated, there may be even more such attacks in the future. Unless any future culprit is apprehended quickly, and countermeasures taken immediately, damage to the infrastructure could be extensive.

Weapons Inadvertently Provided. There are many widespread vulnerabilities to computer systems that are not created as weapons, but whose presence makes the targets of cyberwar highly vulnerable. Poor software designs and inadequate quality control create opportunities for attackers to damage or destroy information, and the information systems themselves.

PENETRATING COMPUTER SYSTEMS AND NETWORKS

MULTIPLE FACTORS INVOLVED IN SYSTEM PENETRATION.

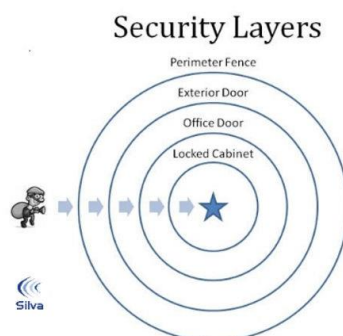
Although penetrating computer systems and networks may sound like a technical challenge, most information security professionals are aware that systems security has both technical and nontechnical aspects. Both aspects come into play when people attempt to penetrate systems. Following are the methods and means by which systems penetrations are accomplished.

- **System Security: More than a Technical Issue**

The primary nontechnical factor in system security and resistance to system penetration is human behavior, which can defeat just about any technical security measure. More than anything else, security depends on human beings to understand and carry out security procedures. Consequently, information system (IS) security must be integral to the culture of any organization employing an information system. Without security, systems and networks will not be able resist attempts at penetration.

Often security is represented as a structure of concentric circles. Protection of the central, secured element is then dependent on the barriers imposed by each successive ring. These barriers can be physical or figurative, but the goal of IS security is to protect the integrity, confidentiality, and availability of information processed by the system. This goal is reached using identification, authentication, and authorization.

Identification is a prerequisite, with each user required to proffer an identifier (ID) that is included in the authorization lists of the system to be accessed. Authentication consists of proving that the user really is the person to whom the ID has been assigned. Authorization consists of defining what a specific user ID, running specified programs, can legally do on the system. The security perimeter can be penetrated by compromising any of these functions.



- **Organizational Culture:**

An organization's general attitude toward security is the key to an effective defense against attack. Security is difficult to sell, especially to an organization that has never experienced a significant problem. (Ironically, the better the defenses, the less evidence there is of their utility.) A basic principle of security is that practitioners must act as if they are paranoid, continuously on guard against attacks from any direction. Many organizations view security precautions as an attack on the integrity of employees. Wearing badges, for example, sometimes is viewed as dehumanizing and offensive. This attitude leads to absurdities, such as having only visitors wear badges. If only visitors wear badges, then taking off the badge automatically reduces the likelihood that a dishonest intruder will be challenged.

Some individual employees also consider security precautions as personally offensive. For example, locking a terminal or workstation when leaving it for a few minutes may be seen as evidence of distrust of other employees. Refusing to allow piggybacking—that is, permitting several colleagues to enter a restricted area on one access card—may be seen as insufferably rude. Where employees are taught to be open and collegial, securing removable computer media and paperwork at night can seem insulting.

These conflicts occur because years of socialization, starting in infancy, are diametrically opposed to the tenets of information security. Politeness in a social context is a disaster in a secure area; for instance, piggybacking into a computer room impairs the accuracy of audit trails kept by the access-control computers. Lending someone a car is kind and generous, but lending someone a user ID and a personal password is a gross violation of responsibility.

NONTECHNICAL PENETRATION TECHNIQUES

Although the penetration of information systems is often portrayed as the work of the technically adept, many successful penetrations have relied on human factors, such as gullibility and venality. Both are exploited by would-be system penetrators.

Misrepresentation (Social Engineering)

Social engineering relies on falsehood. Lies, bribes, and seduction can trick honest or marginally dishonest employees into facilitating a penetration. An attacker might trick an employee into revealing login and authentication codes or even into granting physical access to an otherwise secure site. System penetration can then be accomplished by numerous means, from walking up to an unsecured workstation, to installing Trojan code or a network packet-sniffing device.

- **Lying**

Telling lies is a technique often used by persons intent on obtaining unauthorized access to a system. One can obtain valuable information about a system and its defenses by telling lies. Many lies work by playing on the natural human tendency to interpret the world by our internal model of what is most likely. Social psychologists call this model the schema. Well-dressed businesspeople who walk briskly and talk assertively are probably what they seem. In a phone conversation, a person who sounds exasperated, impatient, and rude when demanding a new password is probably an exasperated, impatient, and rude employee who has forgotten a password. Unfortunately, many criminals know, sometimes instinctively, how to exploit these interpretations to help get them into secured systems.

- **Impersonating Authorized Personnel**

Criminal hackers and unscrupulous employees call security personnel, operators, programmers, and administrators to request user IDs, privileges, and even passwords. (This is one reason that the telephone is a poor medium for granting security privileges; if staff members were trained to refuse requests made over the phone, many attempts to penetrate systems could be thwarted.) In sites where employees wear ID badges, intruders have a hard time penetrating physical security by posing as employees. However, physical security in these cases depends on the cooperation of all authorized personnel to challenge everyone who fails to wear a badge. This policy is critically important at entry points. To penetrate such sites physically, criminals must steal or forge badges or work with confederates to obtain real but unauthorized badges.

- **Intimidation**

A technique related to impersonation of authorized or third-party personnel is intimidation. Someone claiming to be a person in a position of authority displays irritation or anger at delays in granting an unauthorized deviation from policy, such as communicating a password over the phone to a person of unauthenticated identity. The

attackers indirectly or directly threaten alarming consequences (e.g., delays of critical repairs, financial losses, disciplinary actions) unless they are granted restricted information or access to secured equipment or facilities.

- **Subversion**

People make moral choices constantly. There is always a conscious or unconscious balancing of alternatives. Criminal hackers try to reach their goals by changing the rules so that dishonesty becomes more acceptable to the victim than honesty.

- **Bribery**

A lot of industrial and commercial information has a black-market value. The same is true of personally identifiable information that can be used to commit fraud and identity theft. The price of a competitor's engineering plans or customer database may be a year's salary for a computer operator responsible for making backups.

- **Seduction**

Sometimes criminal hackers and spies have obtained confidential information, including access codes, by tricking employees into believing that they are loved. This lie works well enough to allow access to personal effects, sometimes after false passion or drugs have driven the victim into insensibility. It is not unknown for prostitutes to seduce men from organizations that they and their confederates are seeking to crack. Rifling through customers' wallets can often uncover telltale slips bearing user IDs and passwords.

No one can prevent all such abuse. People who are enthralled by expert manipulators will rarely suspect that they are being used as a wedge through a security perimeter. Along with a general increase in security consciousness, staff members with sensitive codes must become aware of these techniques so that they may be less vulnerable. Perhaps then they will automatically reject a request for confidential information or access codes.

- **Extortion**

Criminals can threaten harm if their demands are not met. Threaten someone's family or hold a gun to their head and few will, or should, resist a demand for entry to a secured facility or for a login sequence into a network. Some physical access-control systems include a duress signal that can be used to trigger a silent alarm at the monitoring stations. The duress signal requires a predetermined, deliberate action on the part of the person being coerced into admitting unauthorized personnel. This action may be adding an extra number to the normal pass code, pressing the pound sign (#) twice after entering the code, or entering 4357 (H-E-L-P) into the keypad. The duress signal covertly notifies security that an employee is being forced to do something unwillingly. Security can then take appropriate action.

- **Blackmail**

Blackmail is extortion based on the threat of revealing secrets. An employee may be entrapped into revealing confidential data, for example, using techniques just described. Classic blackmail includes seduction followed by pictures in flagrante delicto (a Latin phrase that means in the very act of committing a misdeed), which the criminals then threaten to reveal. Sometimes a person can be framed by fabricated evidence; a plausible but rigged image of venality can ruin a career as easily as truth. Healthy respect for individuals and social bonds among employees, supervisors, and management can make it difficult for blackmailers to succeed. If employees who are victims of a blackmail attempt feel they can inform management without suffering inappropriately negative consequences, the threat may be mitigated to a certain degree. Perhaps the last, best defense against blackmail is honesty. The exceptionally honest person will reject opportunities that lead to victimization through blackmail and will laugh at fabrications, trusting friends and colleagues to recognize lies when they hear them.

- **Insiders**

Many of the world's largest and most daring robberies have, upon examination, turned out to be inside jobs. The same is true of system penetrations. Although many of the just-described techniques can be used to obtain help from the inside, some are made possible by people on the inside who decide, for whatever reason, to aid and abet criminal hackers. For example, a dishonest employee may actively seek to sell access for personal gain. Organizations should try to be alert to this eventuality, but there is very little defense against thoroughly dishonest employees when the only overt act needed to open the gates from the inside is to pass system credentials to an outsider.

- **Human Target Range**

Organizations should not underestimate the range of targets at which the described techniques may be directed. Although the terms employees, authorized personnel, and third-party personnel are used in the preceding paragraphs, the target range includes all manner of vendors, suppliers, and contractors as well as all levels of employees—from software and hardware vendors, through contract programmers, to soft-drink vendors and cleaning staff. It may even include clients and customers, some of whom possess detailed knowledge of the organization's operations. Employees at every level are likely to be computer literate, although with varying degrees of skill. For example, it is quite possible that someone working as a janitor today knows how to operate a computer skillfully and may even know how to surf hacking sites on the Web and download penetration tools. Indeed, a janitor may have obtained the job specifically with the intent of engaging in industrial espionage, data theft, or sabotage.

In short, anyone who comes into contact with the organization has the potential to provide an attacker with information useful in the preparation and execution of an attack. The human targets of a social engineering attack may not, on an individual basis, possess or divulge critical information, but each may provide clues—pieces of the puzzle—an aggregation of which can lead to successful penetration and compromise of valuable data and resources. Use of this process is a hallmark of some of the most successful criminal hackers. The term incremental information leveraging was coined for this use of less valuable data to obtain more valuable data.

Incremental Information Leveraging

By gathering and shrewdly utilizing small and seemingly insignificant pieces of information, it is possible to gain access to much more valuable information. This technique of incremental information leveraging is a favorite tool of hackers, both criminal and noncriminal. One important benefit of the tool that is particularly appreciated by criminal hackers is the low profile it presents to most forms of detection. By accumulating seemingly innocuous pieces of information over a period of time, and by making intelligent deductions from them, it is possible to penetrate systems to the highest level.

A prime example of this approach is seen in the exploits of Kevin Mitnick, who served almost five years behind bars for breaking into computers, stealing data, and abusing electronic communication systems. Illegal acts committed by Mitnick include the 1981 penetration of Computer System for Mainframe Operations (COSMOS), a Pacific Bell facility in downtown Los Angeles. COSMOS was a centralized database used by many U.S. phone companies for controlling basic recordkeeping functions.

TECHNICAL PENETRATION TECHNIQUES

- **Data Leakage: A Fundamental Problem**

Data leakage refers to the unintentional release of confidential information to unauthorized individuals. *Example:* A financial institution accidentally shares sensitive customer data via a misconfigured cloud storage system.

- **Intercepting Communications**

This involves unauthorized access to private communications, often exploiting unsecured networks. *Example:* Hackers intercept unencrypted Wi-Fi traffic in a coffee shop to steal users' login credentials.

- **Breaching Access Controls**

Exploiting weak or improperly configured access control measures to gain unauthorized entry into systems.

Example: Using a brute-force attack to guess weak admin passwords and gain access to a restricted network.

- **Spying**

The act of covertly monitoring an individual's digital activities through malicious software or surveillance techniques.

Example: An attacker installs spyware on a victim's computer to capture keystrokes and record personal information.

- **Penetration Testing, Toolkits, and Techniques**

Simulating cyberattacks to assess security vulnerabilities, using various tools and methodologies.

Example: A security team conducts a penetration test on an organization's network using Kali Linux to identify potential security gaps.

- **Penetration via Websites**

Attacking web applications by exploiting vulnerabilities such as weak code or insecure inputs.

Example: A hacker uses a Cross-Site Scripting (XSS) attack to inject malicious scripts into a website, compromising users' data.

- **Role of Malware and Botnets**

Malware, often distributed via botnets, can infect and take control of systems for malicious activities like spamming or launching attacks.

Example: A botnet made of thousands of infected devices is used to launch a DDoS attack, flooding a website and taking it offline.

- **Sophisticated Attackers**

Highly skilled attackers, often with substantial resources, who use advanced techniques to infiltrate secure systems.

Example: A state-sponsored cyber espionage group uses zero-day vulnerabilities to penetrate high-security government databases undetected.

MALICIOUS CODE

Malicious logic (or code) is “hardware, software, or firmware that is intentionally included in a system for an unauthorized purpose.” Common types of malicious code include viruses, worms, Trojan horses, spyware, rootkits, and bots. Emerging malicious code threats include kleptographic code, cryptoviruses, and hardware-based rootkits. Present-day malicious code threats do not always fit into neat categories, resulting in confusion when discussing the topic. It is not possible to classify all code as being *good* code or *malicious* code. Absent the *mens rea*, or criminal intent of the author or user, code is neither good nor bad. Authors develop code to achieve some goal or fulfill some purpose just as users run code to achieve some goal or purpose. It is therefore the context of use and the intent of the wielder that determines whether code is malicious.

1. **Viruses**

A virus is malicious software that attaches itself to legitimate files or programs and spreads when those files are shared or executed. It requires user action to propagate.

Example: A file-infecting virus spreads by attaching itself to .exe files, activating when the infected file is run.

2. **Worms**

Worms are self-replicating malicious programs that spread across networks without the need for human intervention. They exploit vulnerabilities in network security.

Example: The infamous "ILOVEYOU" worm spread via email, infecting millions of computers globally by exploiting network weaknesses.

3. **Trojans**

A Trojan is malware disguised as legitimate software, tricking users into installing it. Once inside the system, it can perform harmful actions like stealing data or installing other malware.

Example: A fake antivirus program is downloaded, but instead of cleaning the system, it installs a backdoor for attackers.

4. **Spyware**

Spyware is software designed to secretly monitor a user's activity and gather information without their consent, often for advertising or data theft purposes.

Example: A keylogger records a user's keystrokes to capture login credentials or sensitive information.

5. **Rootkits**

A rootkit is a collection of tools that enables an attacker to maintain privileged access to a system while concealing their presence. Rootkits are typically installed at the operating system level.

Example: A rootkit modifies system files and hides itself deep within the OS, making it difficult for antivirus software to detect.

6. **IRC Bots**

IRC (Internet Relay Chat) bots are programs that connect to IRC servers and are often used by attackers to control botnets. These bots can be used for DDoS attacks or to execute commands remotely.

Example: A bot connected to an IRC server is controlled by a hacker to send spam messages or participate in DDoS attacks.

7. **Malicious Mobile Code**

Malicious mobile code refers to harmful scripts or programs that can be executed on mobile devices, often via web browsers, apps, or email. It can exploit device vulnerabilities for unauthorized access.

Example: A malicious Android app disguises itself as a game but steals the user's personal data and sends it to a remote server.

These types of malicious code pose various risks, ranging from data theft and privacy invasion to system disruption and financial damage.

DETECTION OF MALICIOUS CODE

1. **Signature-Based Malicious Code Detection**

This technique relies on identifying known patterns or "signatures" of malicious code. A signature is a unique string of data that identifies a specific malware. This method is effective for detecting already-known threats.

Example: Antivirus software scans files and compares them against a database of known malware signatures to detect infections.

2. **Network-Based Malicious Code Detection**

This method monitors network traffic for signs of malicious activity. It can detect malware based on abnormal patterns or behaviors in data transmission. It's useful for identifying threats that spread across networks, like worms or botnets.

Example: An Intrusion Detection System (IDS) monitors network traffic and flags any unusual activity, such as a sudden spike in data sent from a single machine, indicating a possible worm outbreak.

3. **Behavioral Malicious Code Detection**

This technique detects malware by monitoring how a program behaves, rather than relying on known signatures. If a program exhibits suspicious actions (e.g., modifying system files, creating new processes), it is flagged as potentially malicious.

Example: A behavioral analysis tool watches a program attempt to modify system registry keys or access protected system files, identifying it as malware.

4. **Heuristic Malicious Code Detection**

Heuristic detection uses rule-based analysis to detect new, unknown, or modified malware. It analyzes code for suspicious characteristics that are typical of malicious behavior. This approach can catch zero-day malware or malware variants that are slightly altered.

Example: A heuristic engine flags a file because it contains obfuscated code and attempts to hide its execution processes, even though it doesn't match any known signature.

Each method has its strengths: signature-based detection is fast but limited to known threats, while behavioral and heuristic methods can identify new or unknown malware. Network-based detection is essential for threats spreading over network environments.

PREVENTION OF MALICIOUS CODE ATTACKS

1. Defense in Depth

This strategy involves using multiple layers of defense to protect systems from malicious code. Each layer is designed to catch threats at different stages, ensuring that even if one defense fails, others will continue to provide protection.

Example: A combination of firewalls, antivirus software, intrusion detection systems (IDS), and encryption is used to protect a network, making it harder for attackers to breach all layers.

2. Operational Controls for Malicious Code

These are policies and procedures that organizations implement to prevent, detect, and respond to malicious code. It includes regular updates, backups, and patch management to keep systems secure.

Example: A company enforces strict software update policies, ensuring all systems are patched against vulnerabilities, while also conducting regular system backups to prevent data loss from ransomware attacks.

3. Human Controls for Malicious Code

Educating and training users is critical, as many attacks succeed through social engineering or user error. Human controls include awareness programs, policies on safe computing, and enforcing secure behavior.

Example: Employees are trained to recognize phishing emails and avoid downloading unknown attachments, reducing the risk of accidentally executing malware.

4. Technical Controls for Malicious Code

These involve the use of security technologies to prevent malicious code from entering or spreading through a system. Technical controls include firewalls, antivirus software, encryption, and access controls.

Example: A company implements endpoint security solutions that use antivirus software and application whitelisting, ensuring only approved programs can run on company devices.

Together, these preventive measures form a comprehensive approach to reducing the risk of malicious code attacks, ensuring security across both technology and human factors.

Mobile Code from the World Wide Web

Mobile code refers to software or scripts that are transferred from a remote system (like a website) to a user's device and executed without the user's explicit consent or knowledge. This code can be embedded in web pages and run within a web browser, allowing websites to enhance interactivity. However, mobile code also poses security risks, as it can be used for malicious purposes.

Motivations and Goals

1. Functionality and Interactivity

The primary motivation for mobile code is to enhance user experience on the web by enabling rich, interactive features like dynamic content, animations, and real-time updates. *Example:* JavaScript is widely used to create interactive websites where users can input data, receive feedback, and view dynamic content.

2. Platform Independence

Mobile code is designed to run on multiple platforms without requiring installation of specific software, making it easier to deploy and use.

Example: Java applets and JavaScript can run on any operating system with a compatible web browser.

3. Efficiency and Performance

Running code locally on a user's machine allows web applications to offload processing from the

server, improving response time and user experience. *Example:* A web-based game uses JavaScript to perform real-time calculations on the user's device, reducing server load.

4. **Malicious Intent**

Some attackers use mobile code to exploit vulnerabilities in web browsers or trick users into executing harmful actions, such as downloading malware or stealing data.

Example: A website injects malicious JavaScript code that captures keystrokes to steal login credentials.

Design and Implementation Errors

1. **Insufficient Input Validation**

When mobile code doesn't properly validate user input, it becomes vulnerable to attacks like Cross-Site Scripting (XSS) or SQL injection. Attackers can inject malicious code into web forms, which the system may execute unintentionally.

Example: A web application fails to sanitize user input, allowing an attacker to inject script tags into a comment field that executes in other users' browsers.

2. **Lack of Proper Authentication and Authorization**

Poorly designed mobile code may not properly enforce access controls, allowing unauthorized users to perform sensitive actions.

Example: A web app allows users to change settings without properly verifying their credentials, leading to unauthorized access.

3. **Insecure APIs**

Mobile code often interacts with web APIs, and if these APIs are not secured, they can expose sensitive data or allow malicious actors to exploit functionality.

Example: An unsecured API used by a mobile app is vulnerable to man-in-the-middle attacks, where hackers can intercept and alter communications between the app and the server.

4. **Improper Error Handling**

Failure to properly handle errors in mobile code can expose sensitive information about the system or allow attackers to bypass security measures.

Example: A JavaScript error message reveals internal system details, helping attackers identify vulnerabilities they can exploit.

SOCIAL-ENGINEERING AND LOW-TECH ATTACKS

Social Engineering Methods

1. **Impersonation**

The attacker pretends to be someone else, such as an employee, vendor, or authority figure, to gain trust and access to sensitive information.

Example: An attacker poses as an IT support technician, asking employees for their login credentials.

2. **Seduction**

The attacker builds a rapport or relationship with the target, gradually manipulating them into revealing sensitive information.

Example: A social engineer befriends an employee over time, eventually convincing them to share confidential business details.

3. **Intimidation**

The attacker uses fear, threats, or pressure to coerce the victim into providing information or performing actions they normally wouldn't.

Example: An attacker calls an employee pretending to be a high-ranking executive and demands immediate access to certain files, threatening consequences for non-compliance.

4. **Low-Tech Attacks**

These attacks don't require sophisticated technology and often involve tactics like dumpster diving, shoulder surfing, or physical theft to gather information.

Example: A hacker sifts through trash outside a business to find discarded documents containing sensitive information.

5. **Network and Voice Methods**

Attackers use phishing, vishing (voice phishing), or other communication methods to deceive victims into divulging confidential information.

Example: A phishing email pretends to be from the company's HR department, tricking employees into entering their login details on a fake website.

6. **Reverse Social Engineering**

Instead of approaching the victim directly, the attacker creates a situation where the victim contacts them, believing they are reaching out for help.

Example: An attacker disables the network and then advertises themselves as the solution, prompting employees to reach out for assistance, unknowingly sharing sensitive information.

Psychology of Social Engineering

1. **Introduction**

Social engineering exploits human psychology, manipulating emotions like trust, fear, or curiosity to gain unauthorized access.

2. **Psychology**

Attackers use psychological principles to exploit human tendencies such as compliance with authority, social proof, or the desire to be helpful.

Example: People are more likely to trust someone in uniform or with an authoritative tone.

3. **Social Psychology**

Social engineering often takes advantage of group dynamics, peer pressure, or the desire to fit in, making individuals more susceptible to manipulation.

Example: An attacker pretends to be part of a well-known group or team, making others feel obliged to assist them.

4. **The Social Engineer Profile**

A successful social engineer is often charismatic, observant, and skilled in reading people, allowing them to manipulate targets effectively.

Dangers of Social Engineering and its Impact on Businesses

1. **Consequences**

Social engineering attacks can lead to financial losses, data breaches, reputational damage, and legal liabilities for organizations.

2. **Case Studies—Examples from Business**

Real-world incidents where businesses fell victim to social engineering attacks highlight the importance of security awareness.

3. **Success Rate**

Social engineering attacks are often highly successful due to human error or lack of awareness, making them one of the most effective cyberattack methods.

4. **Small Business vs. Large Organizations**

Small businesses are particularly vulnerable due to fewer resources for security, while large organizations face complex attacks targeting multiple levels of their structure.

5. **Trends**

Social engineering techniques continue to evolve, with attackers increasingly using sophisticated phishing schemes, deepfake technologies, and social media manipulation.

Detection of Social Engineering

1. **People**

Training employees to recognize social engineering attempts is crucial for early detection and prevention.

2. **Audit Controls and Event Logging**

Monitoring user behavior and tracking suspicious activities can help identify potential social engineering attacks.

3. **Technology for Detection**

Tools like email filtering, multi-factor authentication, and intrusion detection systems (IDS) assist in detecting social engineering tactics.

Response to Social Engineering Attacks

A prompt and coordinated response is essential when a social engineering attack is suspected. This includes reporting incidents, isolating compromised systems, and reviewing access logs.

Defense and Mitigation

1. **Training and Awareness**

Regular training programs help employees recognize and respond to social engineering attempts, reducing vulnerability.

2. **Technology for Prevention**

Tools such as firewalls, email filters, and security software can help prevent social engineering attacks by blocking phishing emails or unauthorized access.

3. **Physical Security**

Securing physical access to buildings, devices, and sensitive documents helps mitigate the risk of social engineering attacks.

Fooling attacks

Fooling attacks, also known as **adversarial attacks**, are a type of cyberattack where attackers manipulate inputs to trick machine learning (ML) or artificial intelligence (AI) systems into making incorrect predictions or classifications. These attacks exploit vulnerabilities in ML models by adding small, carefully crafted perturbations to the input data that are often imperceptible to humans but can cause the model to fail.

Types of Fooling Attacks

1. **Adversarial Examples**

Attackers modify input data, such as images, audio, or text, by adding subtle noise or alterations, which deceive the model into making wrong predictions while the input looks unchanged to humans.

Example: A small modification to an image of a cat might cause a neural network to classify it as a dog, even though the image still looks like a cat to a human observer.

2. **Poisoning Attacks**

These involve tampering with the training data of a machine learning model. Attackers introduce malicious data during the training phase, causing the model to learn incorrect patterns or make wrong decisions.

Example: Inserting malicious data into the training set of a facial recognition system could cause it to misidentify individuals.

3. **Evasion Attacks**

In evasion attacks, attackers present altered inputs to a trained model during its operational phase, bypassing security mechanisms.

Example: An attacker modifies malware files slightly to avoid detection by an AI-powered antivirus system, which then fails to recognize the malicious code.

4. **Model Inversion**

Attackers use the model's outputs to infer sensitive information about the training data. By querying the model with different inputs, they can reverse-engineer certain aspects of the dataset.

Example: Inverting a machine learning model used for medical diagnoses to retrieve personal medical records or confidential data.

Impact of Fooling Attacks

- **Security Risks:** Fooling attacks can bypass security systems such as facial recognition, spam filters, or intrusion detection systems, compromising the integrity of those systems.
- **Misinformation:** These attacks can cause AI systems to make wrong decisions, leading to potential consequences in fields like healthcare, finance, or autonomous vehicles.
- **Privacy Concerns:** Adversarial attacks can be used to extract sensitive information from machine learning models, violating user privacy.

Defense Mechanisms

1. **Adversarial Training**

A method where models are trained with adversarial examples so they can learn to recognize and resist them in the future.

2. **Robustness Testing**

Regularly testing machine learning models against known adversarial attacks and perturbations to evaluate their resilience.

3. **Input Sanitization**

Pre-processing input data by filtering out adversarial noise before feeding it into the model.

4. **Model Hardening**

Using techniques like defensive distillation, which makes the model less sensitive to small perturbations, to improve its robustness against fooling attacks.

Web-based vulnerabilities Introduction

Web-based vulnerabilities are weaknesses in web applications and their underlying infrastructure that can be exploited by attackers. These vulnerabilities can lead to unauthorized access, data breaches, or service disruptions.

Breaking E-Commerce Systems

E-commerce systems are prime targets for attackers due to the sensitive financial and personal data they handle. Common attacks include exploiting vulnerabilities to steal payment information, manipulate transactions, or disrupt services.

Case Study of Breaking an E-Business

1. Target's Data Breach (2013)

Overview: Attackers used stolen credentials from a third-party vendor to access Target's network. They exploited vulnerabilities in the company's network security to install malware and steal payment card information from millions of customers.

Impact: Approximately 40 million credit and debit card records were compromised, leading to significant financial losses and damage to Target's reputation.

2. Capital One Data Breach (2019)

Overview: A former employee of AWS exploited a misconfigured web application firewall to access sensitive data stored on Capital One's servers. The vulnerability allowed the attacker to retrieve personal information from over 100 million credit card applications.

Impact: The breach resulted in a \$80 million fine and substantial damage to Capital One's reputation and customer trust.

Web Application System Security

Web application security involves protecting applications from vulnerabilities that can be exploited through web interfaces. This includes securing code, configurations, and data to prevent unauthorized access and attacks.

Protecting Web Applications

Strategies for protecting web applications include implementing security best practices such as input validation, secure coding practices, and regular security testing to identify and mitigate vulnerabilities.

Components and Vulnerabilities in E-Commerce Systems

1. Client-Side Risks

Example: In 2014, the "Heartbleed" vulnerability in OpenSSL allowed attackers to exploit a flaw in the protocol to read sensitive data from the memory of affected servers. Although not directly a client-side issue, it demonstrated how insecure client-server communication can lead to data breaches.

Mitigation: Implementing secure coding practices and regular vulnerability scans.

2. Network Protocol Risks

Example: In 2018, the "Krack" attack targeted WPA2 encryption in wireless networks, allowing attackers to intercept and manipulate data transmitted between devices and access points.

Mitigation: Regular updates and patches to network security protocols and encryption methods.

3. Business Application Logic

Example: In 2015, the "Ashley Madison" breach revealed how attackers exploited flaws in application logic to access personal user data. Attackers used SQL injection to extract sensitive user data from the database.

Mitigation: Implementing robust input validation and secure coding practices.

4. CGI Script Vulnerabilities

Example: In 2000, the "CGI-bin" vulnerability allowed attackers to exploit a flaw in CGI scripts on many web servers, leading to unauthorized command execution.

Mitigation: Regular updates and security audits of CGI scripts and server configurations.

5. Application Subversion

Example: In 2017, the "Equifax" data breach occurred when attackers exploited a vulnerability in the Apache Struts framework to access sensitive personal information.

Mitigation: Regularly updating and patching software components and configurations.

6. Web Server Exploits

Example: In 2017, the "WannaCry" ransomware attack exploited vulnerabilities in Windows Server to encrypt files and demand ransom payments.

Mitigation: Regular patching and updates to web server software and operating systems.

7. Database Security

Example: In 2017, the “Uber” data breach involved attackers exploiting vulnerabilities to access and steal personal data from 57 million users.

Mitigation: Implementing strong access controls and encryption for sensitive database information.

8. Platform Security

Example: The 2016 “DNC email leak” involved attackers exploiting vulnerabilities in the Democratic National Committee’s IT infrastructure to access and leak sensitive emails.

Mitigation: Hardening operating systems and platforms, and implementing comprehensive security policies.

PHYSICAL THREATS TO COMPUTER SYSTEMS

Physical threats to computer systems involve any risk or danger that can damage or disrupt hardware, software, or data through physical means. These threats can impact the integrity, availability, and confidentiality of computer systems. Here’s an overview of various physical threats:

1. Theft

Description: The unauthorized removal of computer hardware or data storage devices from a facility.

Example: Stolen laptops or external hard drives containing sensitive data can lead to data breaches.

Mitigation: Implement physical security measures such as locks, access control systems, and surveillance cameras.

2. Vandalism

Description: Deliberate destruction or defacement of computer hardware or facilities.

Example: An attacker might physically damage servers or workstations, disrupting operations and causing data loss.

Mitigation: Secure physical access to IT equipment and ensure proper training for staff to recognize and report suspicious activity.

3. Natural Disasters

Description: Events such as floods, earthquakes, hurricanes, or fires that can cause physical damage to computer systems and data centers.

Example: A fire in a data center could destroy servers and storage devices, leading to significant data loss.

Mitigation: Implement disaster recovery plans, use fire suppression systems, and locate critical infrastructure in areas with lower risk of natural disasters.

4. Environmental Threats

Description: Risks related to the physical environment where computer systems are located, such as temperature extremes, humidity, or power fluctuations.

Example: High humidity levels can cause corrosion on electronic components, while power surges can damage sensitive hardware.

Mitigation: Use climate control systems, uninterruptible power supplies (UPS), and surge protectors to maintain a stable environment.

5. Unauthorized Physical Access

Description: Individuals gaining unauthorized access to restricted areas where computer systems or sensitive information are stored.

Example: An intruder accessing a server room and tampering with equipment or data.

Mitigation: Implement strict access control measures, including keycard systems, biometric scanners, and security personnel.

6. Sabotage

Description: Intentional harm to computer systems or infrastructure, often by insiders or disgruntled employees.

Example: An employee intentionally damaging network cables or introducing malware to disrupt operations.

Mitigation: Conduct background checks, monitor employee activities, and enforce strong access controls and auditing procedures.

7. Power Failures

Description: Interruption or loss of power that can lead to system shutdowns or data corruption.

Example: A power outage causing servers to go offline, potentially leading to data loss or service interruptions.

Mitigation: Use UPS systems and backup generators to ensure continuous power supply and protect against data loss.

8. Physical Wear and Tear

Description: Degradation of hardware components due to continuous use, which can lead to failures or malfunctions.

Example: Hard drives or cooling fans failing due to extended use without maintenance.

Mitigation: Implement regular maintenance schedules and replace aging hardware components proactively.

9. Fire

Description: Fire hazards in data centers or server rooms that can cause extensive damage to hardware and data.

Example: An electrical fire damaging servers and storage devices, leading to data loss and operational downtime.

Mitigation: Install fire detection and suppression systems, and ensure that server rooms are equipped with fire-resistant materials.

10. Water Damage

Description: Damage caused by water leaks, floods, or plumbing issues affecting computer systems.

Example: A burst pipe causing water to damage server racks and electronic equipment.

Mitigation: Implement leak detection systems, ensure proper plumbing maintenance, and place critical hardware off the floor.